UPnP Exposure Lab: TP-Link Deco M5

Nov 6, 2026 · @Kushal

Objective

After moving a home network to a single-router topology (ISP gateway in bridge mode, TP-Link Deco M5 as the sole router), the Deco began holding the public IP directly. UPnP was left enabled. The goal was to verify, hands-on, whether that default exposes the network, by answering three questions:

1. Does the Deco accept unauthenticated UPnP requests from any device on the LAN?
2. Can an arbitrary LAN device open an inbound port from the internet to itself with no credentials?
3. Is a port opened that way actually reachable from outside the network?

Environment

Component	Detail
Router under test	TP-Link Deco M5, Wi-Fi Router mode
Gateway (LAN)	192.168.68.1, subnet 192.168.68.0/24
UPnP daemon	MiniUPnPd (banner: 1.8; build date: 2022-08-18)
Upstream	ISP gateway in bridge mode; Deco holds the public IP (redacted: 73.227.x.x)
Test host	Personal laptop, 192.168.68.x, on the main WLAN
External verifier	Phone on cellular (carrier egress 146.75.x.x), off the WLAN entirely
Tools	nmap 7.80 (UPnP NSE scripts), raw SOAP over HTTP via PowerShell, a short TCP listener

All testing was performed on networks and devices owned by the operator. Public and internal addresses are redacted in this report.

Methodology

1. **Discovery.** SSDP scan for the UPnP service on the gateway, then retrieval of the IGD device description (rootDesc.xml) to map the control endpoints.
2. **Information disclosure.** Unauthenticated `GetExternalIPAddress` call against the WANIPConnection service.
3. **Baseline enumeration.** Walked the port-mapping table with `GetGenericPortMappingEntry` to record any pre-existing mappings.
4. **Exploit.** Issued an unauthenticated `AddPortMapping` request mapping a public port to the test host, then started a local listener.
5. **External verification.** Reached the mapped port from a device on the cellular network and confirmed the hit in the listener log.
6. **Teardown.** Removed the mapping with `DeletePortMapping`, removed the temporary firewall rule, and verified the table was clean.

Findings

#	Finding	Severity	Evidence
1	UPnP IGD is advertised on the LAN and answers without authentication	Medium	SSDP open on 1900/udp; rootDesc.xml and control URLs retrievable by any LAN client
2	Public IP disclosed to any LAN device on request	Low	`GetExternalIPAddress` returned the WAN IP, no credentials
3	Baseline: no pre-existing mappings	Informational	Empty port-mapping table (UPnP error 713 at index 0)
4	Any LAN device can open an internet-facing port to itself, unauthenticated	High	`AddPortMapping` accepted; mapping confirmed in the table and reachable from the internet

Lesson: verify the banner against a second source

The SSDP scan reported `MiniUPnPd/1.8`, a version string old enough to suggest known CVEs. The IGD device description told a different story: the WANConnectionDevice modelNumber was `20220818`, placing the actual build in the 2.3.x era. The banner was a

hard-coded string, not the real build. The exposure here is the configuration (UPnP on, directly facing the WAN), not a specific daemon CVE. Treat a version banner as a lead, not a conclusion.

Proof of concept

The port mapping was created with a single unauthenticated SOAP call to the WANIPConnection control URL, mapping external TCP 18080 to the test host on port 8080 with a one-hour lease:

```
AddPortMapping -> ExternalPort 18080 / TCP -> 192.168.68.x:8080 / lease 3600s
```

The router accepted it with no prompt, no credential, and no notification in the Deco app UI. A minimal TCP listener was then started on 8080.

From a phone on cellular (Wi-Fi off), a browser request to the public IP on port 18080 returned the test page. The listener logged two inbound connections:

```
17:37:30  from 146.75.x.x  GET / HTTP/1.1
17:37:30  from 146.75.x.x  GET / HTTP/1.1
```

The source address sits in the carrier egress range, not the 192.168.68.0/24 LAN, confirming the traffic entered from the public internet, traversed the UPnP-created mapping, and reached the test host.

Teardown

`DeletePortMapping` removed the mapping; the temporary inbound firewall rule was removed; and a follow-up `GetGenericPortMappingEntry` returned the empty-table error, confirming no mappings remained. The lease would also have expired on its own within the hour.

Risk assessment

Overall: High, conditional on a compromised or untrusted LAN device.

UPnP by itself does not let an outside attacker in. The risk is that it removes the authorization step for anything already on the LAN. The implicit trust model is the problem: the daemon treats every device on the network as authorized to open inbound holes.

Factor	Assessment
Attack prerequisite	A foothold on any LAN device (malware on a laptop, a compromised IoT device)
Impact	Unauthenticated, persistent inbound exposure of any internal host to the internet
Visibility	Low. The mapping did not surface in the router app UI, so the owner has no obvious signal
Real-world relevance	Mirai-class malware and some RATs use UPnP exactly this way to self-expose and establish reachability
Mitigating factor	Mappings carry a lease and expire; this does not help against malware that simply renews them

The move to a single-router topology raised the stakes: the Deco now holds the public IP, so a UPnP-opened port faces the internet directly rather than sitting behind a second NAT layer.

Remediation

1. **Disable UPnP on the router** unless a specific device requires it. Baseline enumeration showed zero legitimate mappings, so turning it off costs nothing here. (Deco app: More > Advanced > NAT Forwarding > UPnP.)
2. **If UPnP must stay on**, periodically audit the active mappings and investigate any from a device you do not recognize.
3. **Segment untrusted devices.** Keep IoT devices and any untrusted hosts on an isolated guest network, away from trusted machines, so a single compromise cannot pivot or self-expose alongside them.
4. **Prefer explicit port forwards** over UPnP for anything that genuinely needs inbound access. They are deliberate, visible, and owner-controlled.
5. **Keep router firmware current**, and do not rely on a version banner to judge patch level.

Decision

UPnP disabled. No device on the network required it, and the operator keeps a work device and a lab environment on the same premises, where unauthenticated inbound exposure is an unacceptable default.